

# TechPulse AI — Tratamento dos 20 PRs do Dependabot

Registro detalhado da triagem, validação e decisão de cada atualização de dependência aberta pelo Dependabot no repositório [leonardodebs/tech-insights-blog](#).

| DATA        | PRs TRATADOS     | APLICADOS | REJEITADOS | PRs ABERTOS |
|-------------|------------------|-----------|------------|-------------|
| 27 jul 2026 | 21 (20 + 1 novo) | 13        | 6          | 0           |

## 1. Contexto: por que 20 PRs de uma vez

O Dependabot foi ativado no repositório como parte da fase 2 da auditoria de segurança, para abrir automaticamente Pull Requests sempre que uma dependência tiver atualização disponível. Ao ser ligado, ele fez uma **varredura inicial** de todo o projeto e abriu de uma só vez um PR para cada dependência desatualizada — daí os 20 PRs simultâneos. Isso é um acúmulo pontual, esperado; a partir de agora ele abre PRs em ritmo normal (1 a 2 por vez), conforme surgem novas versões.

**Restrição importante:** os workflows de CI do projeto disparam em push para a branch main, não em pull\_request. Ou seja, os PRs do Dependabot **não são validados automaticamente** por testes. Mergear qualquer um às cegas poderia quebrar o build ou o pipeline de deploy sem aviso.

## 2. Metodologia adotada

Em vez de mergear os PRs pela interface do GitHub, cada atualização foi puxada para um clone local, onde foi submetida à mesma bateria de verificação usada no projeto:

|           |                                                                                                                  |
|-----------|------------------------------------------------------------------------------------------------------------------|
| 1. Lint   | tsc --noEmit — checagem de tipos; pega API de dependência que mudou (ex.: assinatura de função, ícone removido). |
| 2. Testes | vitest run — 50 testes cobrindo validação de post, saneamento de markdown, LinkedIn e MFA.                       |
| 3. Build  | npm run build — Vite + geração de sitemap/RSS + SSG das 127 páginas de post.                                     |

**Princípio de decisão:** aplicar o que tem ganho real de segurança e passa nas três checagens; rejeitar atualizações que quebram sem trazer benefício. Ferramentas de build e de desenvolvimento (Vite, Vitest, Express) **não vão para o navegador do visitante**, então uma CVE nelas afeta no máximo a máquina do desenvolvedor ou o runner de CI — nunca o site publicado.

## 3. Atualizações aplicadas (13)

| PACOTE                | VERSÃO          | TIPO  | MOTIVO / IMPACTO                                           |
|-----------------------|-----------------|-------|------------------------------------------------------------|
| date-fns              | 4.1.0 → 4.4.0   | minor | Formatação de datas na UI. Sem breaking dentro do major 4. |
| tailwind-merge        | 3.5.0 → 3.6.0   | minor | Merge de classes Tailwind. Patch de correção.              |
| helmet                | 8.1.0 → 8.3.0   | minor | Security headers do servidor de dev. Dentro do major.      |
| dotenv                | 17.3.1 → 17.4.2 | minor | Carga de variáveis de ambiente. Patch.                     |
| @supabase/supabase-js | 2.99 → 2.110    | minor | SDK do banco/Auth. Dentro do major 2, compatível.          |

| PACOTE            | VERSÃO                                    | TIPO   | MOTIVO / IMPACTO                                                                                                                  |
|-------------------|-------------------------------------------|--------|-----------------------------------------------------------------------------------------------------------------------------------|
| motion            | 12.23 → 12.42                             | minor  | Animações. Dentro do major 12.                                                                                                    |
| react / react-dom | 19.0 → 19.2                               | minor  | Framework. Patch dentro do major 19.                                                                                              |
| marked            | 18.0.5 → 18.0.7                           | patch  | Markdown → HTML no build (SSG). Correção.                                                                                         |
| tsx               | 4.21 → 4.23                               | minor  | Executa TypeScript no Node (scripts e CI).                                                                                        |
| transitivos       | body-parser, ws, qs, postcss, @babel/core | patch  | Sub-dependências (via express/vite). Atualizadas pelo npm update dentro do major. Cobre os PRs #26, #23, #25, #24, #28.           |
| vitest            | 2.1.9 → 4.1.10                            | MAJOR  | Resolve o CVE crítico do vitest (GHSA-5xrq-8626-4rwp, dev-only). Todos os 50 testes passam com a v4; a config não precisou mudar. |
| vite              | 6.2.0 → 6.4.3                             | minor  | Mantido dentro do major 6 (o 8 quebra — ver seção 5). O 6.4.3 já resolve o CVE do vite sem quebrar o build.                       |
| @anthropic-ai/sdk | 0.98.1 → 0.115.0                          | PR #31 | Motor de geração dos posts. A API usada (messages.create com tool_use) continua compatível — validado com lint, testes e build.   |

#### 4. GitHub Actions do pipeline (5)

As 5 actions dos workflows de deploy foram atualizadas em commit separado das dependências npm, para permitir reversão cirúrgica caso o pipeline quebrasse — o site continua servindo a última versão boa até um deploy bem-sucedido. Bump conservador (um major por vez) em vez das versões mais novas propostas pelo Dependabot, por estabilidade: são apenas o runner de CI, sem exposição ao visitante.

| ACTION                        | VERSÃO  | OBSERVAÇÃO                                                                                                                      |
|-------------------------------|---------|---------------------------------------------------------------------------------------------------------------------------------|
| actions/checkout              | v4 → v5 | Dependabot pediu v7; aplicado v5 (conservador). PRs #10.                                                                        |
| actions/setup-node            | v4 → v5 | Idem, v5 em vez de v7. PR #11.                                                                                                  |
| actions/configure-pages       | v5 → v6 | Casou com o alvo do Dependabot. PR #13.                                                                                         |
| actions/upload-pages-artifact | v3 → v4 | <b>Importante:</b> a v3 depende de upload-artifact@v3, que o GitHub está descontinuando. v4 parecia com deploy-pages v5. PR #9. |
| actions/deploy-pages          | v4 → v5 | Par compatível com upload-pages-artifact v4. PR #12.                                                                            |

Resultado no CI: todos os steps do deploy (Checkout, Setup Node, Setup Pages, Upload artifact, Deploy to GitHub Pages) executaram com sucesso após o bump.

#### 5. Atualizações rejeitadas (6)

Cada PR abaixo foi fechado com um comentário explicando a decisão. Nenhum traz ganho de segurança que justifique o risco de quebra.

| PACOTE               | VERSÃO | MOTIVO DA REJEIÇÃO                                                                                                                                                                                                 |
|----------------------|--------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| vite                 | 6 → 8  | <b>Quebra o build.</b> O Vite 8 não aceita mais manualChunks em formato objeto (usado no vite.config.ts para separar vendor/supabase/markdown/motion). Build-only, sem exposição ao navegador. Incluído no PR #29. |
| @vitejs/plugin-react | 5 → 6  | Requer Vite 7+, que traria o problema acima. Mantido plugin 5.x com Vite 6.x. PR #15.                                                                                                                              |

| PACOTE             | VERSÃO       | MOTIVO DA REJEIÇÃO                                                                                                                                                                               |
|--------------------|--------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| lucide-react       | 0.546 → 1.27 | A v1 <b>removeu os ícones de marca</b> (Twitter, LinkedIn, GitHub) por questão de trademark — quebraria o rodapé (erro de compilação nos imports). Nunca foi sinalizado como vulnerável. PR #16. |
| express            | 4 → 5        | Major com breaking changes. O express só é usado no server .ts (servidor de desenvolvimento local), <b>não vai para o bundle publicado</b> . Sem CVE embarcado. PRs #21, #25.                    |
| actions/checkout   | (→ v7)       | Aplicado v5 em vez de v7, por estabilidade. É só o runner de CI. PR #10.                                                                                                                         |
| actions/setup-node | (→ v7)       | Idem — aplicado v5. PR #11.                                                                                                                                                                      |

## 6. Verificação e resultado

|                       |                                                                                                                |
|-----------------------|----------------------------------------------------------------------------------------------------------------|
| Commits               | 3 (deps seguras · GitHub Actions · @anthropic-ai/sdk), todos isolados por tema                                 |
| Validação local       | lint + 50 testes + build verdes antes de cada push                                                             |
| Validação em produção | Deploy no CI com o gate de testes (vite 4); site respondendo HTTP 200                                          |
| PRs fechados          | 13 auto-fechados ao aplicar as versões + 6 fechados manualmente com justificativa + 2 confirmados já-aplicados |
| Estado final          | 0 PRs abertos · pipeline íntegro · nenhuma CVE embarcada no bundle do navegador                                |

Documento gerado em 27/07/2026. Cada atualização aplicada foi verificada em produção (deploy no ar, não apenas build local). Os pacotes de build e desenvolvimento não são servidos ao visitante; decisões sobre eles priorizaram a integridade do pipeline sobre a atualização por si só.